

PROJECT REPORT

Defend against cyberthreats with Microsoft Defender XDR

Student name	Yassine Nemri
Date	October 3, 2026
Platform	Microsoft Defender XDR (security.microsoft.com)

Table of contents

Introduction

In this project, I worked with Microsoft Defender XDR to protect an organization against cyberthreats. Defender XDR brings detection, investigation and response together in one portal, which lets me see what is happening on an endpoint and react to it quickly.

Over four chapters, I onboarded a device and simulated an attack, built a policy to block a malicious JavaScript technique, investigated a multi-stage incident, and collected forensic evidence before isolating the affected machine. Each chapter below explains what I did, the steps I followed, and the screenshots that prove the result.

Objectives

- Create a device group with automatic remediation and onboard Client2.
- Simulate an attack on Client2 with the provided PowerShell script.
- Create an endpoint security policy that blocks JavaScript from launching downloaded executable content.
- Investigate the incident, then create a custom indicator and a custom detection rule.
- Run a live response session, collect an investigation package and isolate Client2.

Chapter 1 - Device group and onboarding of Client2

In this chapter, I prepared the environment for protection. I created a device group named Group1 that remediates threats automatically, I onboarded Client2 to Microsoft Defender XDR, and I then ran the sample attack script to generate activity to investigate later.

1.1 Creating the device group Group1

I started with the device group so that Client2 would land in a group that fixes threats on its own.

1. In the Defender portal, I went to Settings > Endpoints > Permissions > Device groups and selected Add device group.
2. I named the group Group1 and set the remediation level to Full - remediate threats automatically.
3. On the Devices tab, I added a matching rule so that the group covers devices where the OS is Windows 10 and Windows 11.
4. I reviewed the settings and submitted the group.

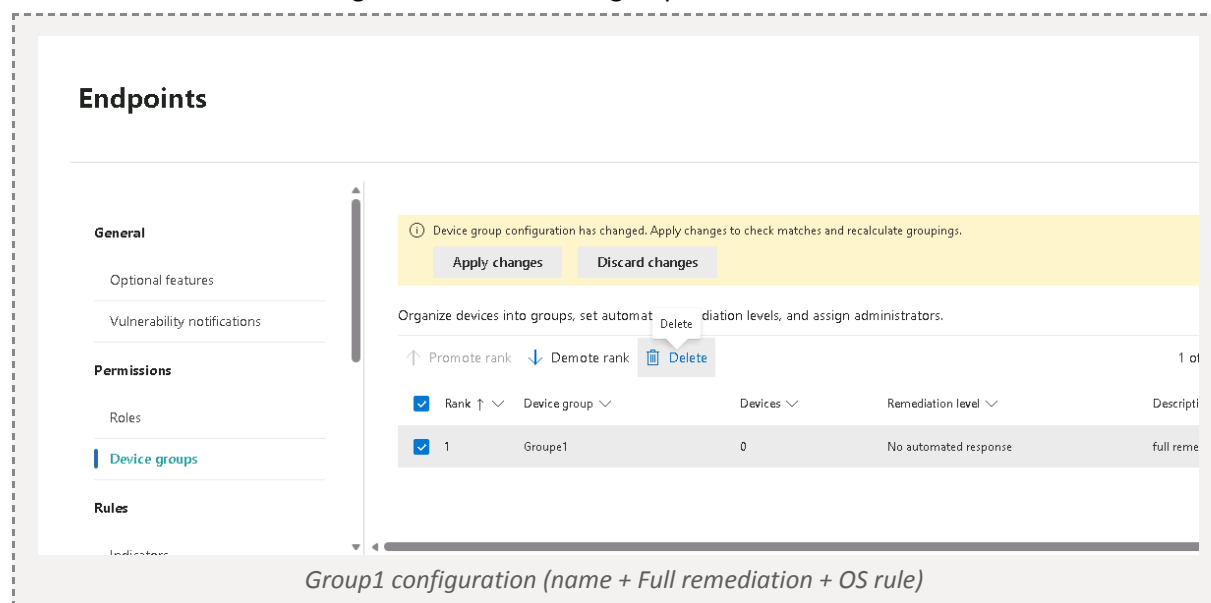


Figure 1 - Device group Group1

1.2 Onboarding Client2

Next, I onboarded Client2 using the streamlined connectivity type, so the device can reach the simplified domains such as *.endpoint.security.microsoft.com.

1. I went to Settings > Endpoints > Device management > Onboarding.
2. I chose Windows 10 and 11 as the operating system, Streamlined as the connectivity type and Local Script as the deployment method.
3. I downloaded the onboarding package and saved it in the Downloads folder on Client2.
4. I extracted the package and ran the onboarding script as administrator, then confirmed.

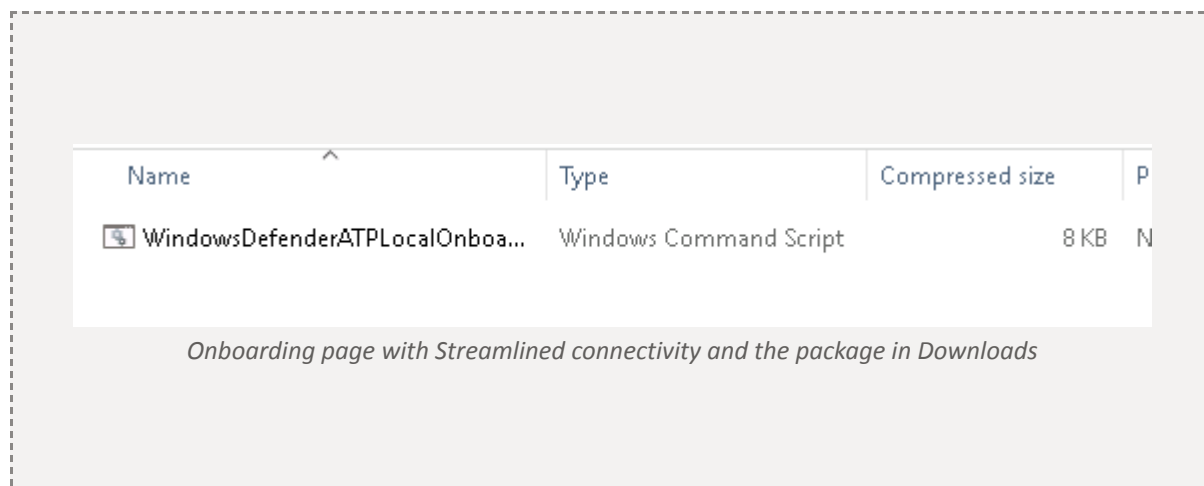


Figure 2 - Onboarding package

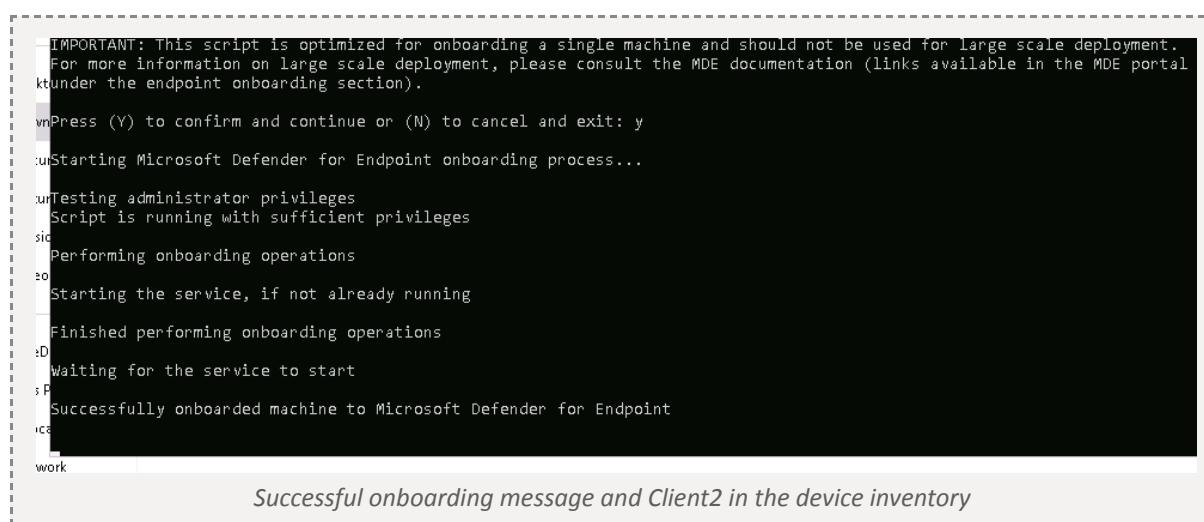


Figure 3 - Client2 onboarded

1.3 Simulating the attack

Once Client2 appeared in the portal, I simulated an attack to produce alerts and an incident.

1. I opened Windows PowerShell as administrator on Client2.
2. I moved to C:\Files and ran the sample attack script. I ignored the message "Failed to resolve Domain Controllers in the domain", as instructed.

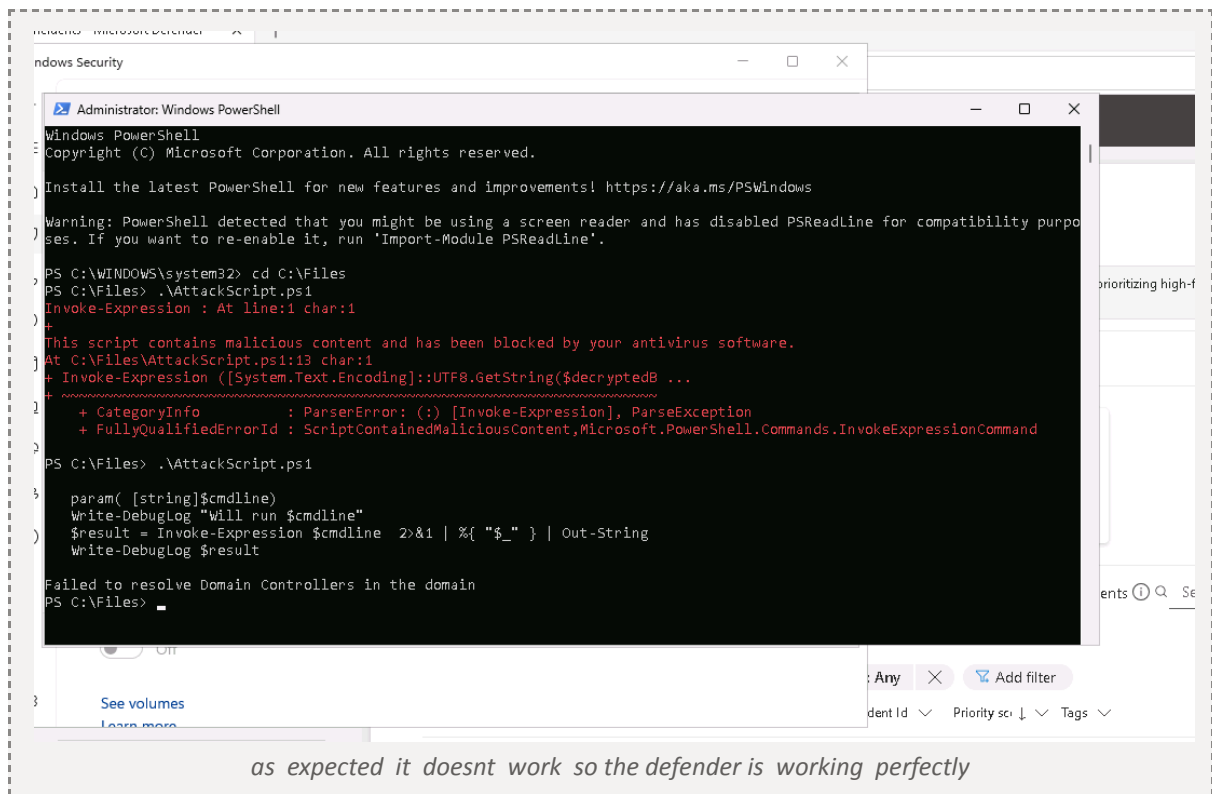
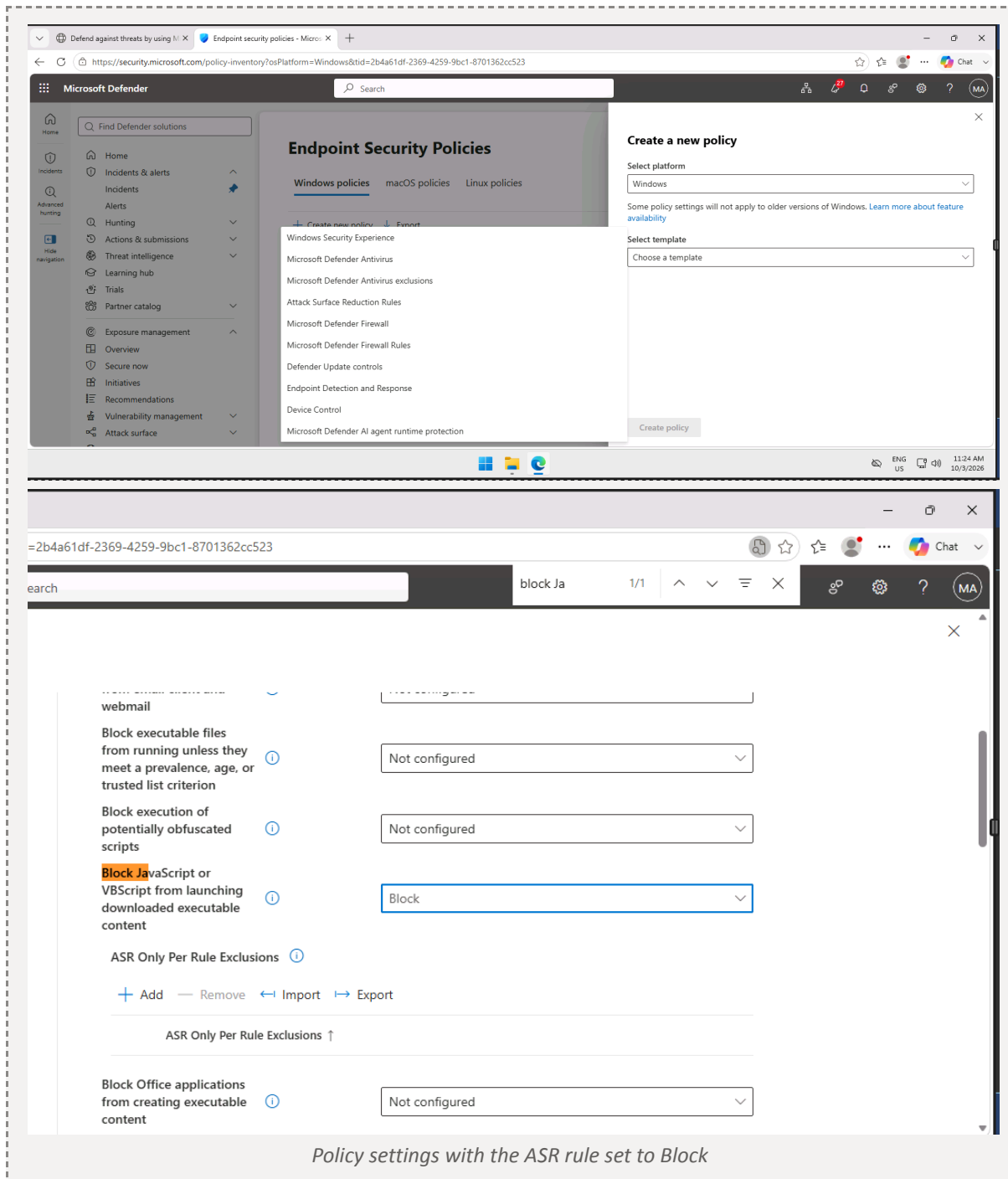


Figure 4 - Attack simulation on Client2

Chapter 2 - Endpoint security policy EndpointPolicy1

Reports said that company executives downloaded and ran a malicious JavaScript file. In this chapter, I created a policy that stops JavaScript from downloading and running executable content on Windows 11 devices, and I assigned it to the sg-Executive security group. I did this chapter from Client1.

1. I went to Endpoints > Configuration management > Endpoint security policies and selected Create new policy.
2. I chose the platform Windows 10, Windows 11, and Windows Server and the profile Attack surface reduction rules.
3. I named the policy EndpointPolicy1.
4. I set the rule "Block JavaScript or VBScript from launching downloaded executable content" to Block.
5. In Assignments, I added the sg-Executive group.
6. I reviewed the policy and created it.



Policy settings with the ASR rule set to Block

Figure 5 - EndpointPolicy1 settings

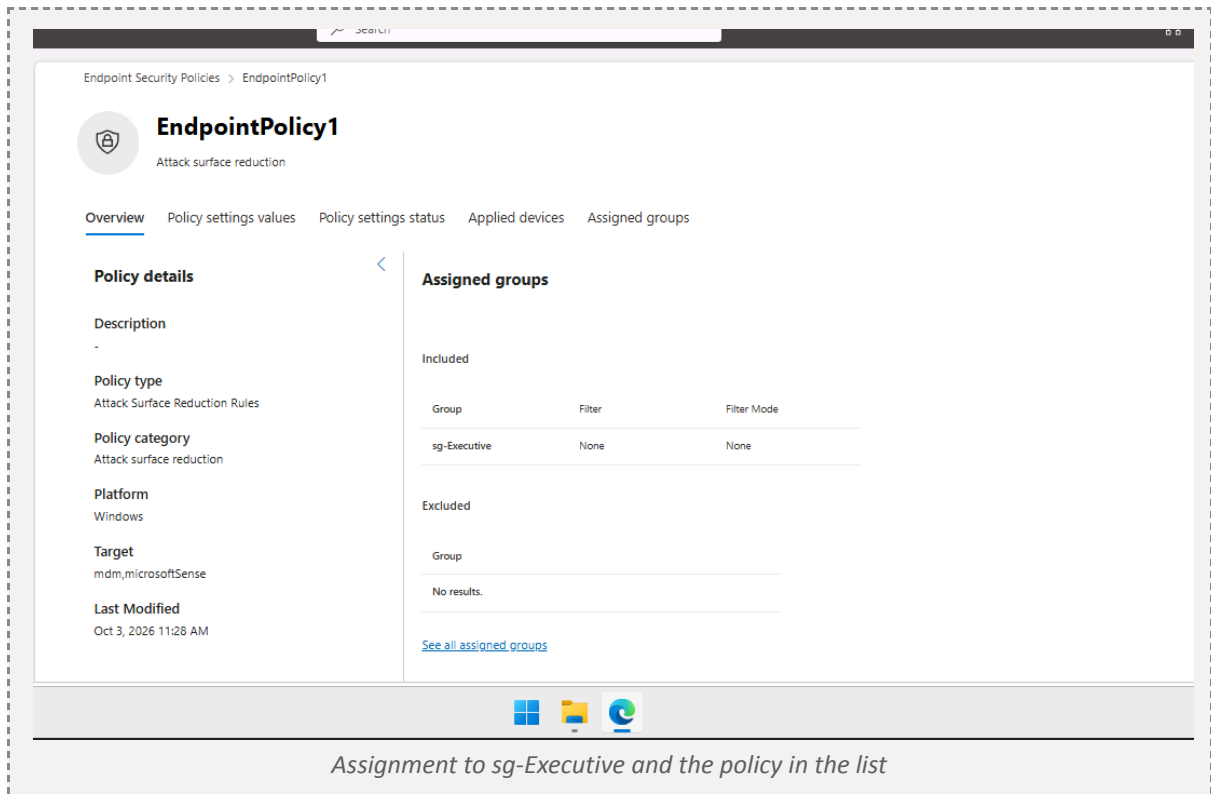


Figure 6 - EndpointPolicy1 assigned to sg-Executive

Chapter 3 - Incident investigation

In this chapter, I investigated the incident "Multi-stage incident involving Defense evasion & Discovery on one endpoint". I did this chapter from Client1. I reviewed the timeline of Client2 to find the malicious IP address and the target of the process hollowing, then I built a block indicator and a detection rule from what I found.

3.1 Reviewing the Client2 timeline

1. I went to Incidents & alerts > Incidents and opened the incident.
2. I opened the Client2 device page and selected the Timeline tab.
3. I found the suspicious process injection entry and noted the outbound connection to the malicious IP address and the executable that PowerShell performs process hollowing on.

The screenshot displays the Microsoft Defender XDR interface. The top section shows the 'Incidents' page with a search bar and a sidebar. A 'Multi-alert incidents' tooltip is visible, explaining that an incident is a collection of related alerts. The 'Most recent incidents and alerts' section shows 'Attack disruptions' as 'None' and 'Multi-alert incidents' as '50%'. Below this, a filter set is shown with 'Status: Any', 'Alert severity: Any', and 'Priority score: Any'. The bottom section shows the 'Device timeline' for 'client2', with a 'Suspicious process injection observed' alert. The timeline shows three events: 'Suspicious process injection observed', 'powershell.exe possibly injected', and 'powershell.exe used process hollowing'. The 'Device timeline - suspicious process injection entry' is highlighted.

Device timeline - suspicious process injection entry

Figure 7 - Process injection event on Client2

Malicious IP address	102.104.139.237
Target executable	Notepad.exe

3.2 Creating the custom indicator Indicator1

To stop the connection to the malicious IP address, I created a custom indicator.

1. I went to Settings > Endpoints > Rules > Indicators, opened the IP addresses tab and selected Add item.
2. I entered the malicious IP address and chose the action Block execution.
3. In the alert settings, I enabled Generate alert, set the severity to High and the category to Execution.
4. I set the scope to All devices in my organization and named the indicator Indicator1.

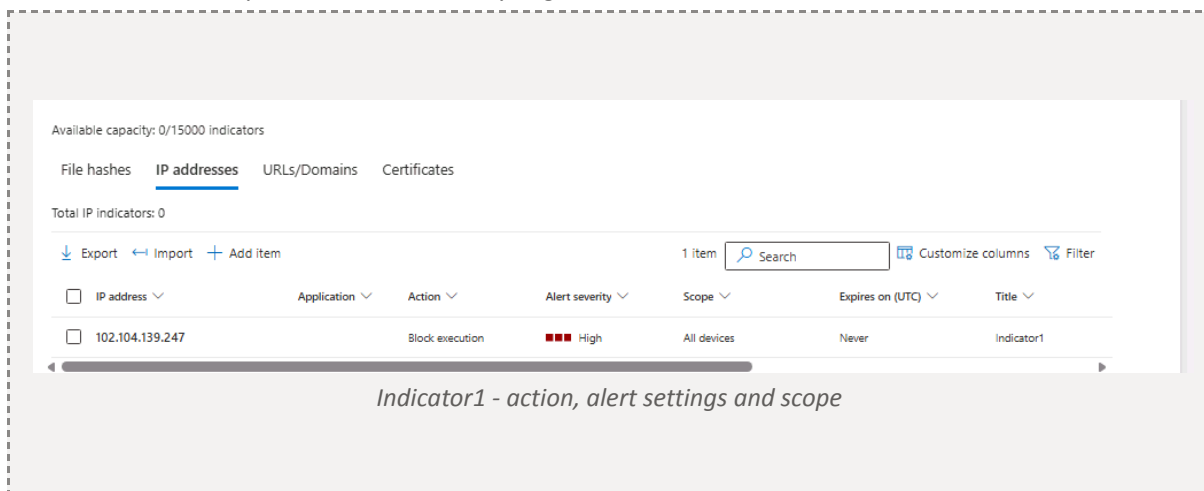


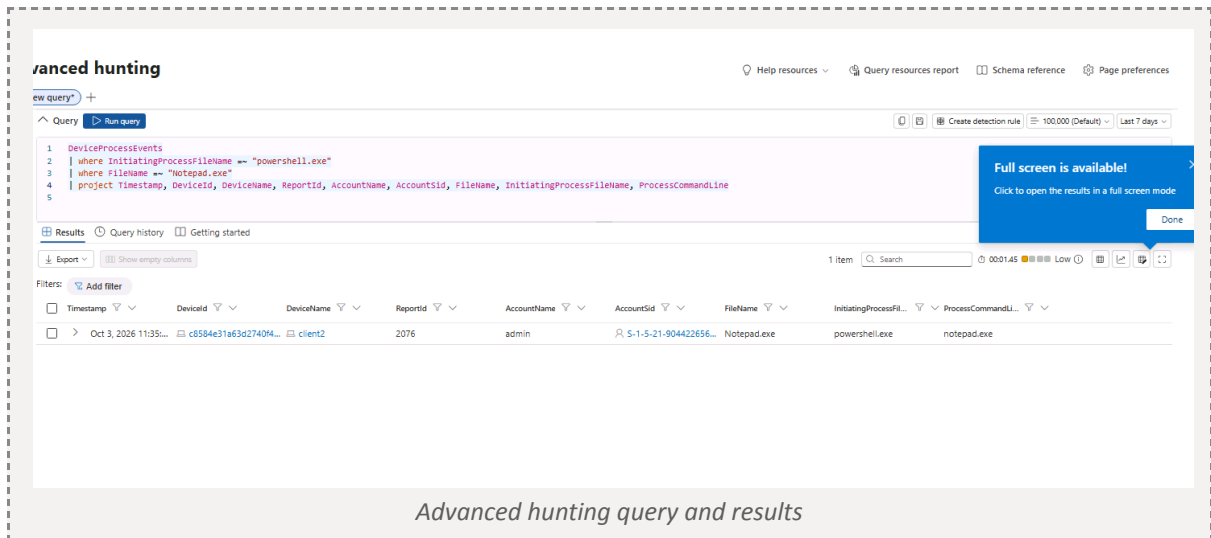
Figure 8 - Indicator1

3.3 Creating the detection rule SuspiciousPowershell

Finally, I created a detection rule that finds PowerShell starting the target executable, so the same behavior is caught again automatically.

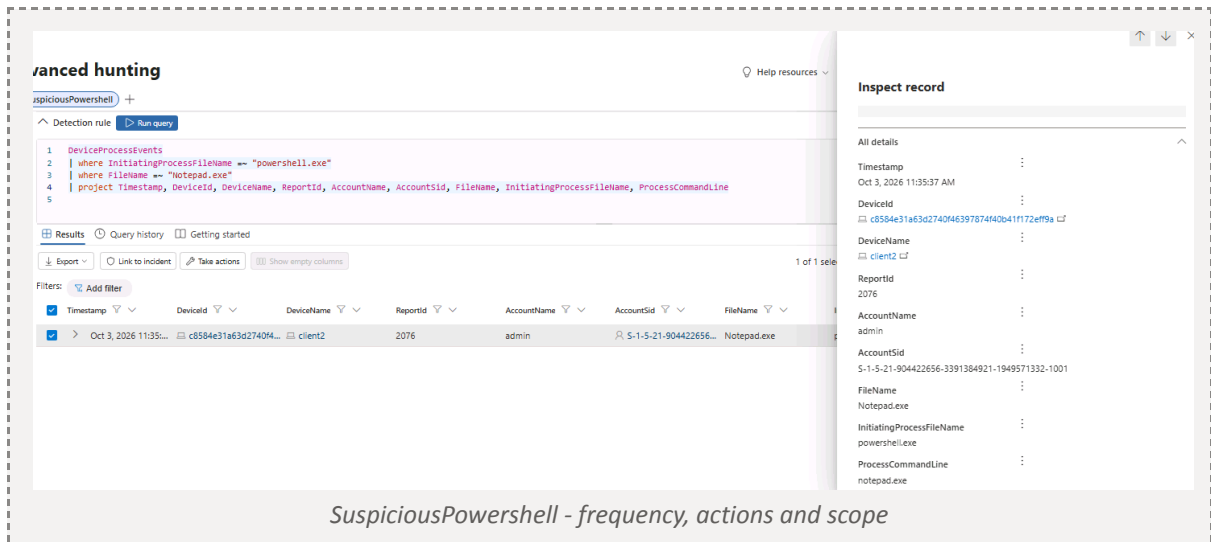
1. I opened Hunting > Advanced hunting and wrote a query on the DeviceProcessEvents table (shown below).
2. I selected Create detection rule and named it SuspiciousPowershell, with a frequency of every hour.
3. For the impacted entities I chose Device and User.
4. For the actions, I chose Collect investigation package and Mark user as compromised.
5. I scoped the rule to all devices and saved it.

```
DeviceProcessEvents
| where InitiatingProcessFileName =~ "powershell.exe"
| where FileName =~ "<TARGET_EXECUTABLE>"
| project Timestamp, DeviceId, DeviceName, ReportId, AccountName, AccountSid,
AccountObjectId, FileName, InitiatingProcessFileName, ProcessCommandLine
```



Advanced hunting query and results

Figure 9 - KQL query in advanced hunting



SuspiciousPowershell - frequency, actions and scope

Figure 10 - Detection rule SuspiciousPowershell

Chapter 4 - Forensic evidence collection on Client2

In the last chapter, I collected forensic evidence from Client2 and contained the machine. I did this chapter from Client1.

4.1 Live response

1. I went to Settings > Endpoints > General > Advanced features, turned on Live response and saved.
2. On the Client2 device page, I opened the actions menu and selected Initiate live response session.
3. In the console, I ran the command connections to view the current connections of Client2.

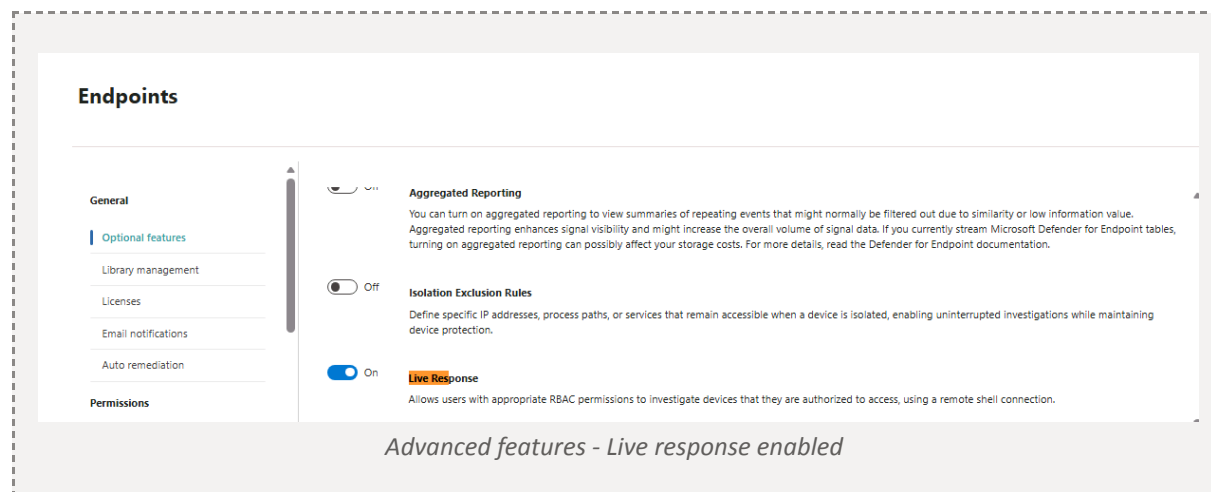
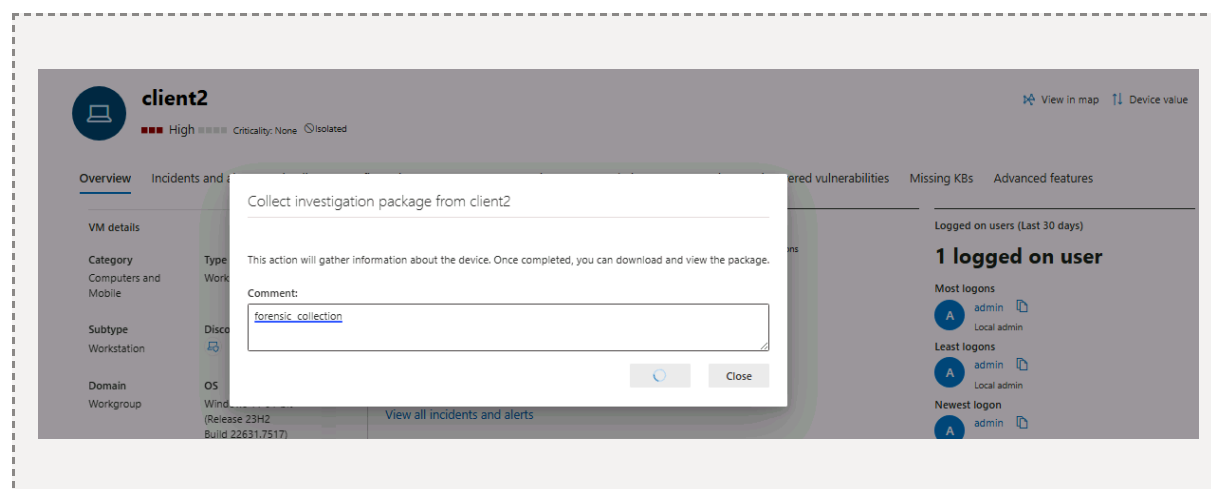


Figure 11 - Live response enabled



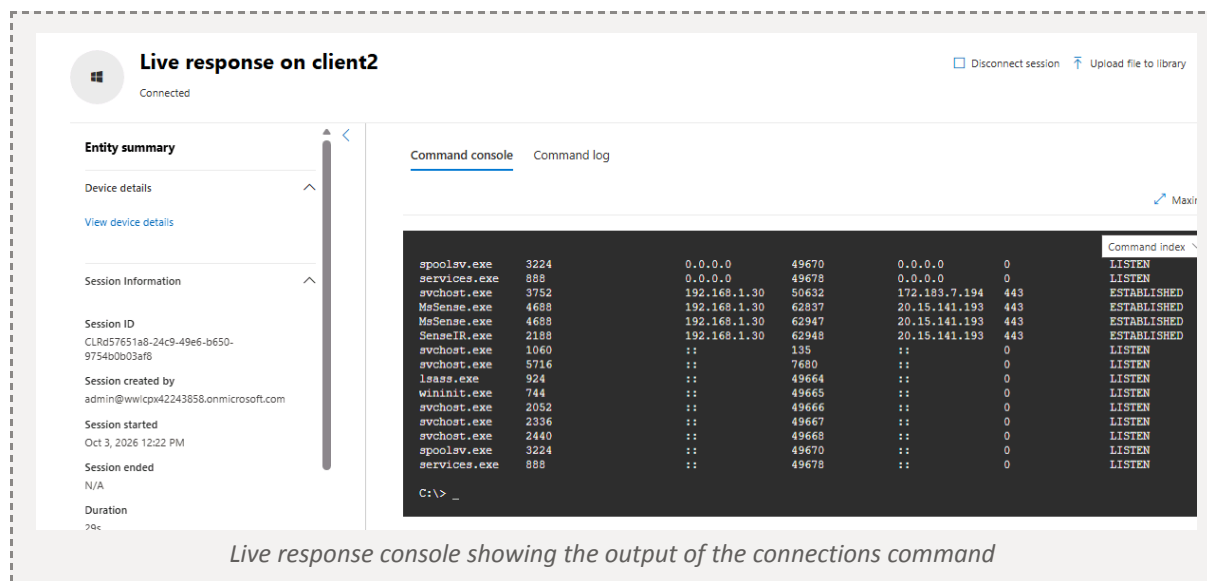


Figure 12 - Current connections on Client2

4.2 Investigation package

1. On the Client2 device page, I selected Collect investigation package and added a comment.
2. When the collection finished, I downloaded the package from the Action center.
3. I extracted the package, found Forensics Collection Summary.csv and saved it in C:\Files on Client1.

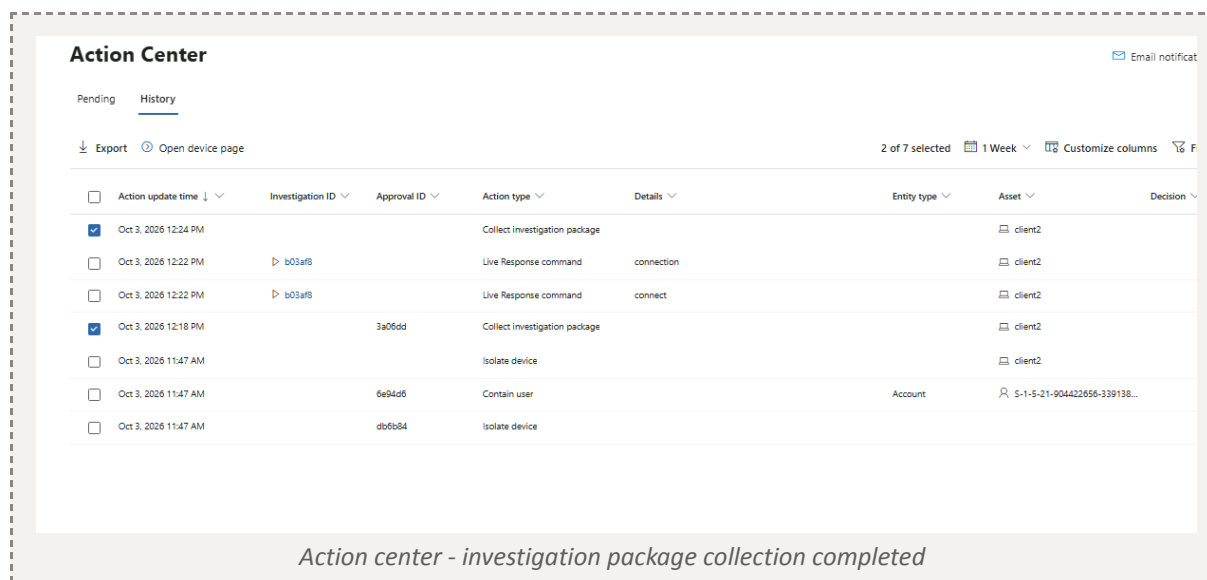


Figure 13 - Investigation package collected

Conclusion

Through this project, I onboarded Client2 into a device group with automatic remediation, created an attack surface reduction policy against malicious JavaScript, investigated a multi-stage incident, and put in place a block indicator and a recurring detection rule. I then used live response, an investigation package and device isolation to collect evidence and contain the endpoint.